# Information Systems Security

Arrianto Mukti Wibowo, M.Sc.,

Faculty of Computer Science
University of Indonesia

*amwibowo@cs.ui.ac.id*

# Security Management Practices

# Tujuan

- Mempelajari cara untuk mengidentifikasi asset perusahaan (terutama information asset), berikut cara terbaik untuk menentukan tingkat pengamanannya, serta anggaran yang patut untuk implementasi keamannnya.

# Topik

- Responsibilities, administration, organization security model, security requirements for business, risk management, risk analysis, policies, procedures, standards, data classification, layers of responsibility, security awareness

# Background

- What is Security Management?
  - Q: Apa yang anda lakukan jika menemukan disk dengan label “confidential” berada di meja makan?
  - Q: Apakah anda pernah mendapatkan user ID dan password supervisor?
  - Q: Apakah orang luar dapat menggunakan PC dan mencoba log-on ke sistim komputer?
  - Q: Apa yang harus dilakukan jika laptop perusahaan hilang?
  - Q: Apa yang harus dilakukan jika saya ingin mengirimkan data “confidential” ke kantor cabang melalui e-mail?
- Security Management:
  - Proses manajemen dalam melindungi informasi dan IT services pada tingkatan keamanan tertentu.
  - Identifikasi aset dan pengembangan keamanan dlm implementasi kebijakan, standard, guidelines dan prosedur.
  - Praktik manajemen: analisa resiko dan klasifikasi data/aset TI.

# Security Management: Issues

- Security Management IT => part of manager's job
  - Bertanggung-jawab dalam melindungi informasi (information protection) terhadap insiden keamanan
  - Berhubungan dengan kebijakan/strategi dan operasionil => bagian dari quality (assurance) management
- Issues:
  - Insiden: event yg dapat terjadi baik disengaja atau tidak yang merugikan **nilai dari informasi**
  - Meniadakan insiden? Sulit dilakukan!
    Mencapai "acceptable level" dari resiko.
  - Faktor penting perlindungan nilai dari informasi:
    **Kerahasiaan**, **Integritas** dan **Ketersediaan** **informasi**

# Information Security

- Information security merupakan metode & teknologi untuk melindungi informasi:
  - Confidentiality (privacy),
  - Integrity, and
  - Availability
- Kategori utama: Big Three (C.I.A)
  - Prinsip dasar perlindungan data dan services TI
  - Tolak ukur terhadap: perlindungan (safeguard), ancaman (threat), kerawanan (vulnerability) dan proses manajemen keamanan.

.

# Confidetiality (Kerahasiaan)

- What information needs to be kept secret?
- Kerahasiaan:
  - Pencegahan terhadap usaha yang disengaja atau tidak yang melanggar otorisasi untuk mengakses/menyerbarkan informasi.
  - Informasi: sensitif dan rahasia

- How much protection is needed?
- For how long must the information be kept secret?

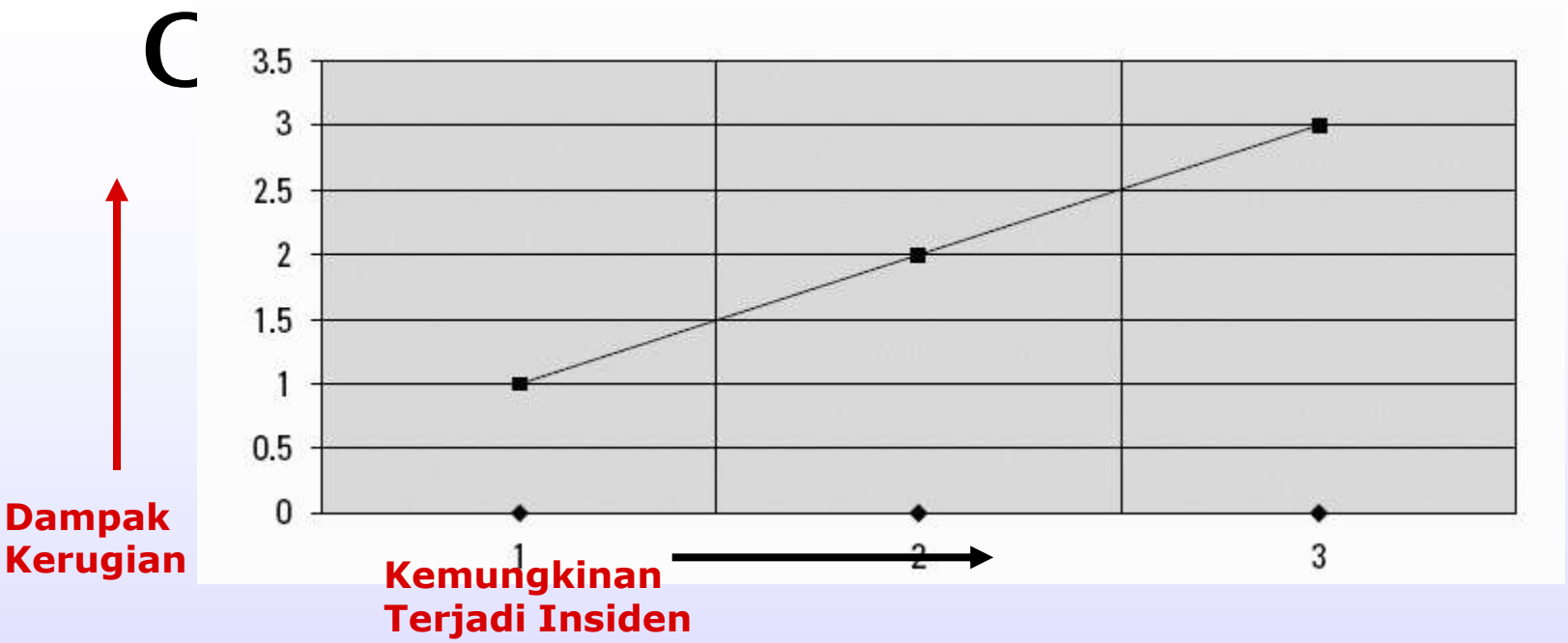
# Integrity (Keutuhan)

- Information that cannot be trusted is worse than useless—it costs money and time to create and store, but provides no benefit.
- Integrity:
  - Pencegahan terhadap modifikasi data oleh orang yang tidak berhak atau perubahan yang tidak di-otorisasi.
  - Konsistensi data/informasi: eksternal dan internal
  - Who create/send the information?
  - Can we prove who create the data?
  - We know the information is not changed or altered by "unauthorized personnel"

# Availability (Ketersediaan)

- Information which is not available when required is of no use, even if its confidentiality is secure and its integrity intact
- Availability:
  - Menjamin informasi/services tetap ada saat diperlukan.
  - What information must we have readily available?
- How readily must we be able to access the information?
  - Days?, Hours?; Minutes or seconds?

# C




- Security controls:
  - Sulit utk ancaman dan dampak kerugian.
  - Feasible: mengurangi atau menurunkan dampak kerugian maupun kemungkinan terjadi insiden
  - Sebagai contoh: objektif dari security control dapat menurunkan matrix di atas dari titik 3, ke titik 2 atau titik 1.

# Security components

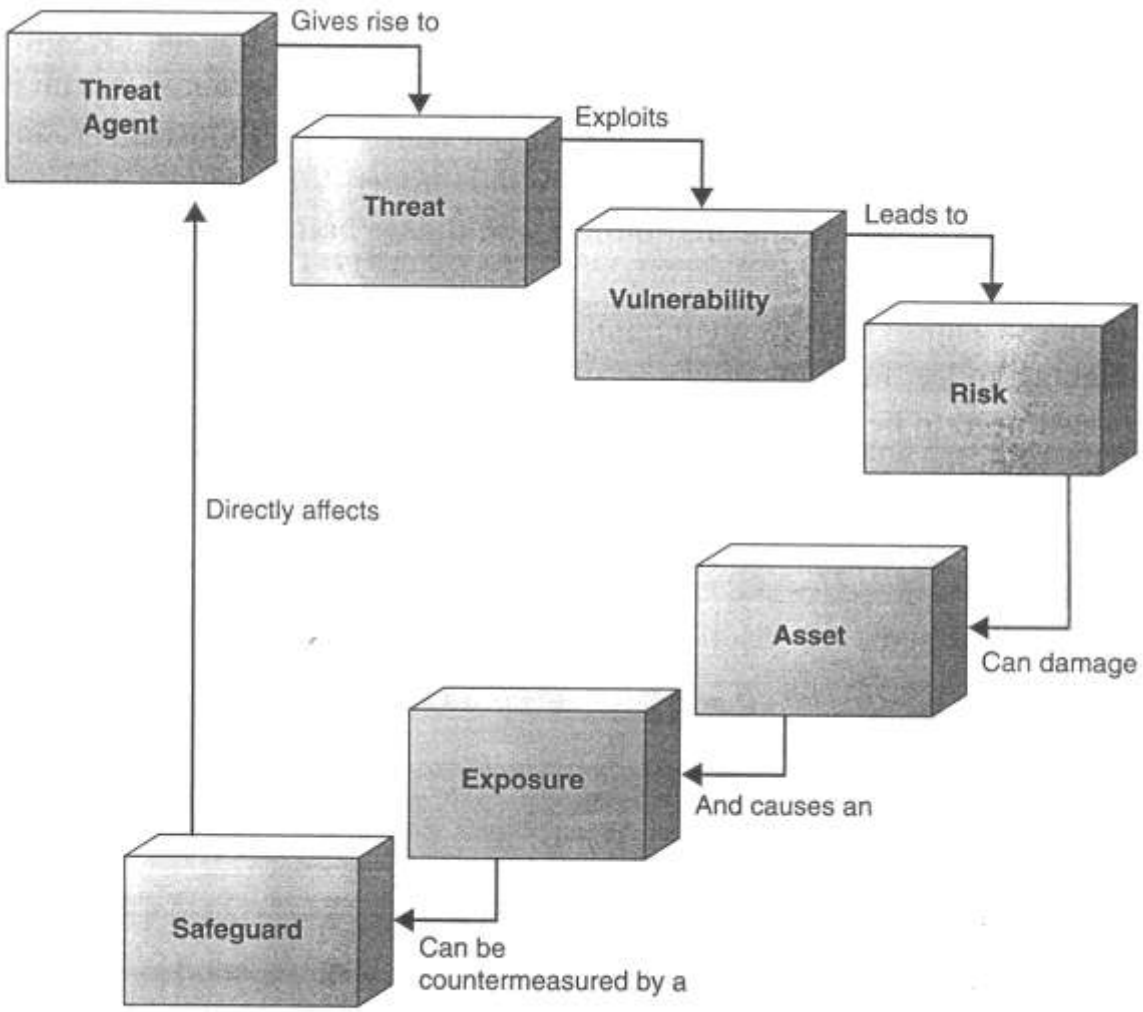
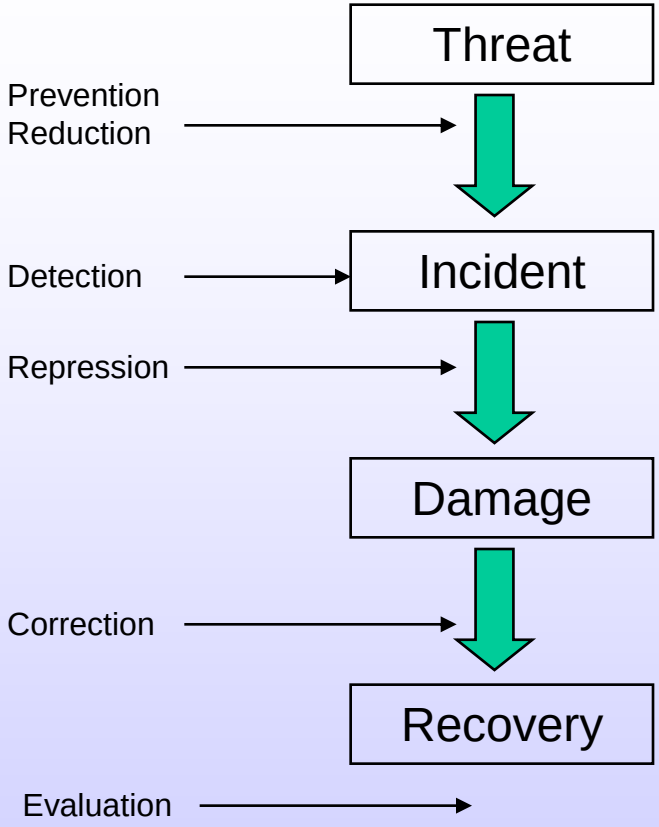



**Figure 3-3** The relationships between the different security components


Threat
Prevention
Reduction
Detection
Incident
Repression
Damage
Correction
Recovery
Evaluation

# Security Measures (1)

- Tindakan Keamanan
  - Tidak semua informasi sama penting/bernilai => perlu klasifikasi jenis aset (informasi + services) yang perlu dilindungi.
  - Manajemen: pertimbangan faktor cost (waktu, SDM dan biaya) dlm melindungi informasi
  - Required resources vs tingkat proteksi yang diperlukan
- Insiden => Tindakan Keamanan yang diperlukan
  - Mencegah dan menangani insiden yg dapat terjadi pada setiap tahapan

# Contoh

**Table 3-1** Relationship of Threat Agents, Vulnerabilities, and Risks

| Threat Agents | Can Exploit This Vulnerability | Resulting in This Risk |
|---|---|---|
| Virus | Lack of antivirus software | Virus infection |
| Hacker | Powerful services running on a server | Unauthorized access to confidential information |
| Users | Misconfigured parameter in the operating system | System malfunction |
| Fire | Lack of fire extinguishers | Facility and computer damage, and possibly loss of life |
| Employee | Lax access control mechanisms | Damaging mission-critical information |
| Contractor | Lax access control mechanisms | Stealing trade secrets |
| Attacker | Poorly written application | Conducting a buffer overflow |
| Intruder | Lack of security guard | Breaking windows and stealing computers and devices |
| Employee | Lack of auditing | Altering data inputs and outputs from data processing applications |
| Attacker | Lack of stringent firewall settings | Conducting a denial of service attack |

## Maintanance:

Learn
Improve

## Plan:

Service level agreemnts
Contracts
Policy Statements
Operational Level Agreements

## Control:

Get Organized
Establish management framework
Allocate responsabilities

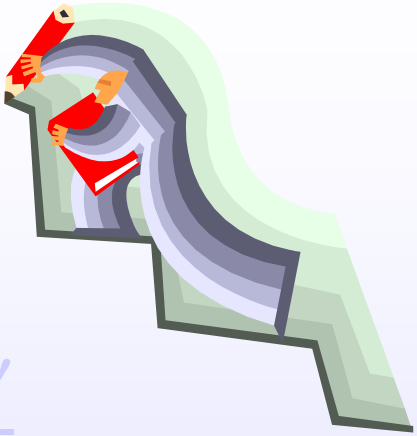
## Evaluate:

Internal audits
External audit
Self assessment
Security incidents

## Implement:

Create awareness
Personal security
Physical sec
Control access rights
Security incident handling

# Metodologi Manajemen Keamanan

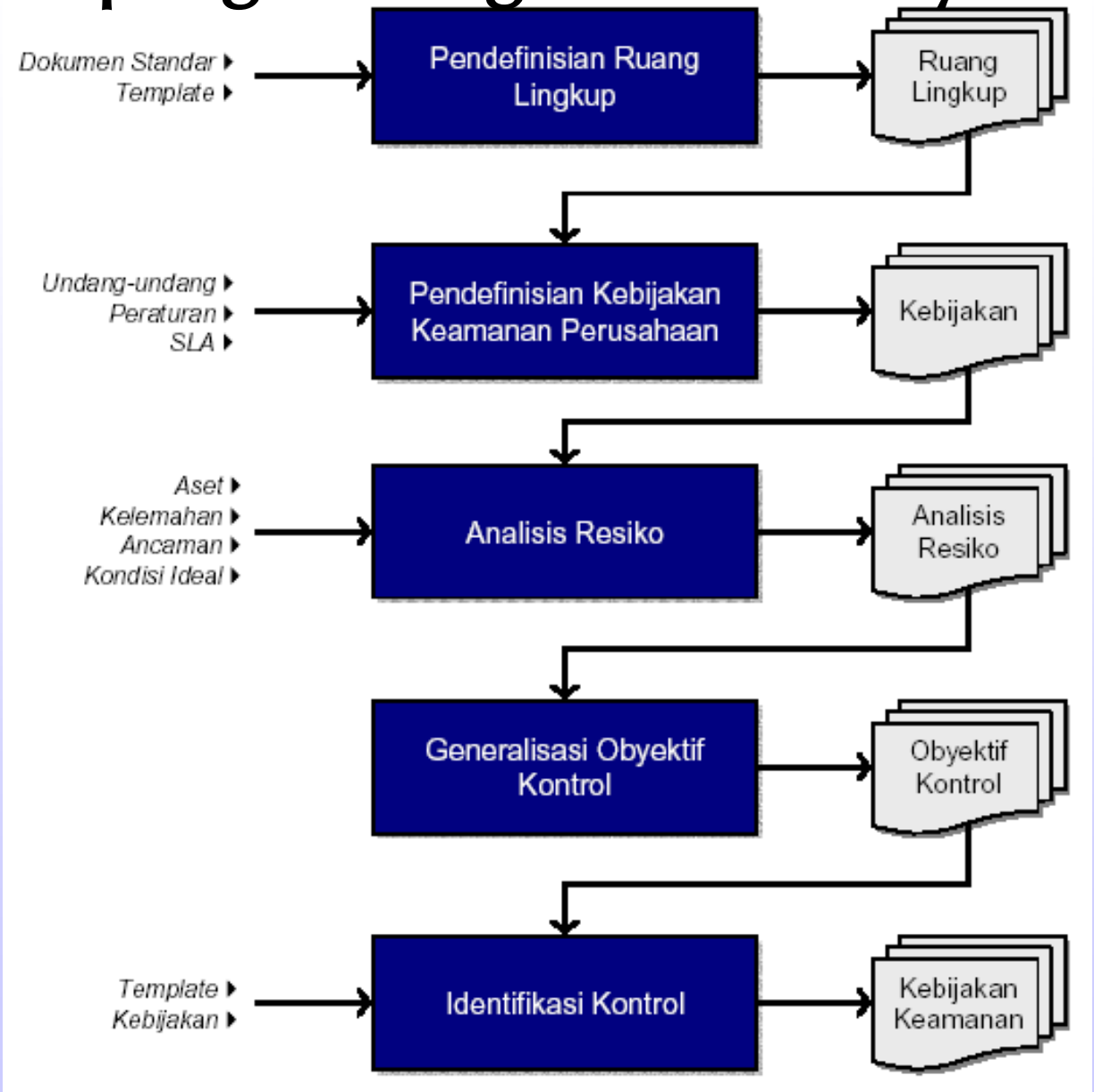


- Kebijakan "Corporate Security"
- Perencanaan Manajemen Sekuriti
- Analisis Resiko
- Controls & Countermeasures

# Corporate Security Policy

- Juga disebut "Information Risk Management (IRM) Policy"
- Komponen yang ada di dalamnya:
  - Komitmen dan dukungan direksi
  - Filosofi akses: biasanya "deny all - need to know basis"
  - Prinsip pemberian akses
  - Kepatuhan terhadap aturan yang berlaku
  - Kesadaran sekuriti bagi seluruh pegawai
  - Penunjukkan manajer sekuriti komputer
  - Pembentukan steering committee sekuriti komputer
  - Audit keamanan sistem informasi

# Metode pengembangan IT Security Policy



# Perencanaan Manajemen Sekuriti

- Survey awal terhadap status keamanan
- Membuat *template* analisis strategis terhadap resiko keamanan, yang cocok dengan kebutuhan perusahaan

# Analisis Strategik Terhadap Resiko?

- Keuntungan expert jaringan, mantan hacker, dsb:
  - lebih tahu secara teknis (secara mikro)
- Kelemahannya:
  - tidak komprehensif, memungkinkan ada yang ketinggalan
  - technology oriented, not business driven
- Keuntungan analisis resiko secara strategik:
  - komprehensif
  - business driven
  - melihat berbagai kemungkinan pertahanan (baik dengan komputer atau tidak)
  - bisa dipakai untuk decision making strategis

# Contoh template

## Threat & Vulnerability Worksheet

Sheet number:

1. **Vulnerability**:
2. **Threat**: (Destruction/Denial/Theft/Modificaiton/Fraud)
3. **Impact**:
4. **Frequency (ARO)**:
5. **Single Loss Expectancy**:
6: **Annualized Loss Expectancy:**:
7. **Rationale**
8. **Recommended Countermeasures**

## Countermeasure Evaluation Worksheet

Sheet number:

1. Countermeasure:

2. Description:

3. Annual costs:

4. Threats affected by countermeasure:

| | ALE | |
|---|---|---|
| Current | Projected | ALE Savings |

5. Return on Investment

6. Overlapping additional countermeasures

# Analisis Resiko

- Asset Identification
- Threat Identification
- Vulnerability Analysis
- Impact analysis
- Countermeasures

# Asset Identification

- Tangible assets:
  - hardware, media penyimpanan (tapes, discs)
  - staff
  - ruangan
- Intangible assets (<u>information assets</u>):
  - Software (ada yang memasukkannya ke dalam tangible asset)
  - Informasi & data mentah

# Information Asset Valuation

- Replacement cost: berapa biaya untuk membangun kembali informasi yang hilang. Kalau tidak ada backup sangat sulit (bisa mustahil)
- Cost akibat:
  - hilangnya kerahasiaan informasi (*confidentiality*)
  - rusaknya informasi (*integrity*)
  - tidak tersedianya informasi (*availability*)

# Teknik Valuasi

- Bisa dinilai secara:
  - kualitatif
  - kuantitatif murni ($)

# Pendekatan Kualitatif

Membuat skala / skor terhadap:

- availability dari asset informasi: “Tidak Penting” sampai “Penting”
- integrity dari asset informasi: “Tidak Pelu Akurat” sampai “Perlu Akurat” (dalam banyak kasus digabung dengan availability)
- confidentiality dari asset informasi: “Tidak Rahasia” sampai “Rahasia”
- gabungan ketiganya

# Valuasi Kuantitatif Secara Finansial

- *Information Economics*, dari Parker (1988) atau Remenyi (1995), tetapi "dibalik":
  - berapa kerugian finansial jika informasi yang dibutuhkan tidak ada?
- *Guidelines for Information Valuation*, yang dikeluarkan oleh Information System Security Association (www.issa.org), menggunakan teknik Delphi

# Threat Identification

- Penghapusan (destruction)
  - mis: penghapusan hutang scr tak sah
- Pemutusan akses (denial):
  - mis: Denial Of Service dari sebuah webserver
- Pencurian (theft / disclosure):
  - mis: hacking kartu kredit di payment gateway
- Pengubahan (modification):
  - mis: mengubah nilai gaji dalam payroll
- Penipuan (fraud):
  - mis: Trojan horse, typosquatting (kilkbca.com)

# Dari mana informasi ancaman?

- Catatan satuan pengamanan
- Log komputer
- Laporan network monitoring application
- Komplain-komplain dari user
- Laporan kegiatan operasional
- dsb.

# Threat Frequency

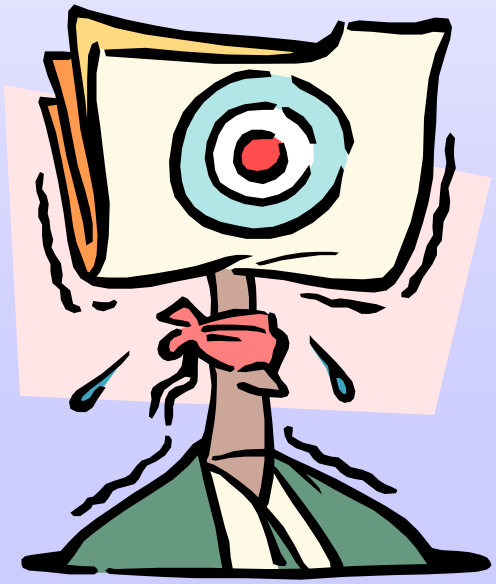
- Seberapa sering ancaman itu terjadi?
- Misalnya:
  - Kebakaran besar: 1 dalam 40 tahun
  - Banjir besar: 1 dalam 6 tahun
  - System crash: 1 dalam 6 bulan
  - Unauthorized access: 2 dalam 1 bulan
- Dihitung dalam Annualized Rate of Occurance (ARO):
  - Kebakaran: 1/40
  - Banjir besar: 1/6
  - System crash: 2
  - Unauthorized access: 2 x 12 = 24

# Vulnerability Analysis

- Tidak adanya pengamanan akan membuat frekuensi atau besarnya kerugian membesar. Dengan kata lain, "makin rentan"
- Akan mempengaruhi nilai dari EF (exposure factor) dan ARO (Annualized Rate of Occurance)

# Contoh Kerentanan (*Vulnerability*)

- Teknologi yang digunakan belum teruji
- Pilihan password yang buruk
- Transmisi data tanpa enkripsi
- Minimnya access control (pengelolaan user login yang buruk)
- dll.
- Kesalahan konfigurasi sistem
- Kesalahan proses bisnis
- Buruknya standar sekuriti



# Kalau ada resiko, lantas?

- Resiko diminimalisir → residual risk yang lebih kecil
- Resiko dicegah / dieliminasi
- Resiko ditransfer → asuransi
- Resiko diterima → karena resiko memangkecil

# Impact Analysis

- Single Loss Expectancy
- Annualized Loss Expectancy
- Qualitative risk modelling

# Single Loss Expectancy

- Kerugian finansial yang muncul dalam suatu (1) bencana
- SLE = Asset Value x Exposure Factor
- Exposure Factor: 0%-100%, yakni besarnya prosentasi kerugian yang diderita dalam satu bencana
- Misal:
  - Dalam suatu bencana banjir, akan menyebabkan ATM terendam di 30% lokasi di Jakarta. Replacement cost ATM = Rp.100 juta/ATM. Total ATM yang dimiliki 200 unit
  - SLE = Rp. 100 juta x 30% x 200 = Rp. 6 milyar

# Annualized Loss Expectancy

- ALE =
  Single Loss Expectancy x
  Annualized Rate Of Occurance
- Dalam kasus ATM, SLE = Rp. 6 milyar dan ARO = 1/6
- Maka ALE = Rp. 6 milyar x 1/6 = Rp. 1 milyar
- Dibaca: "Setiap tahunnya diperkirakan akan ada biaya ATM yang harus diperbaiki/diganti akibat banjir sebesar Rp. 1 milyar"

# Qualitative Risk Modelling

**Nilai "Information Asset"**

**Resiko** (kemungkinan terjadi, kemungkinan kerugian per kasus, dll)

| | Kecil | Sedang | Tinggi |
|---|---|---|---|
| Kecil | | | |
| Sedang | | | |
| Tinggi | | | |

Fokuskan pengamanan mulai dari sini

# Controls

- Controls:
  - Preventive: pencegahan, misalnya pemisahan tugas staf adminstrator, sekuriti & data entry
  - Detective: pendeteksian, misalnya pengecekan ulang & audit
  - Corrective: memperkecil dampak ancaman, misalnya: prosedur backup & restorasinya
- Countermeasures
- Post-control analysis / risk mitigation analysis

# Strategi Countermeasures

- Least previlage: orang hanya diberikan akses tidak lebih dari yang dibutuhkan
- Defense in Depth: pertahanan yang berlapis
- Choke point: keluar masuk pada satu gerbang saja
- Weakest link: “sebuah rantai hanya sekuat mata rantai yang paling lemah”
- Fail-Safe Stance: kalau sebuah perangkat rusak, maka settingnya akan di-set ke yang paling aman secara otomatis

- Universal participation: semua harus ikut serta!
- Diversity of Defence: menggunakan beberapa jenis sistem yang berbeda untuk pertahanan
- Simplicity: harus sederhana agar sistem keamannya dapat dipahami dengan baik

# Mitigation Analysis

Contoh kasus:

- Misalnya ada sebuah bank penerbit kartu kredit, yang ternyata pintu masuk ke ruang komputernya tidak aman.

# Threat & Vulnerability Worksheet

Sheet number: 01

1. **Vulnerability**:

Physical Access, lemahnya pengawasan keluar-masuk di pintu masuk.

2. **Threat**: (Theft/Destruction)

3. **Impact**:

a. Pengubahan data kartu kredit (pemalsuan) bisa untuk menghapus data tagihan.

b. Pencurian seluruh data transaksi pelanggan untuk dijual ke pihak ketiga

4. **Frequency (ARO)**:

Destruction: 1 kali setahun

Theft: 1 kali dalam 5 tahun

5. **Single Loss Expectancy**:

Destruction: diperkirakan Rp. 50 juta

Theft: diperkirakan tuntutan class action Rp. 1 milyar

6: **Annualized Loss Expectancy:**:

Destruction: Rp.50 juta x 1 = Rp.50 juta

Theft: Rp.1.000 juta x 1/5 = Rp. 200 juta

7. **Rationale**

Sangat mungkin hanya dengan berpakaian necis dan menyapa satpam dengan ramah, untuk masuk ke dalam ruang komputer. Programmer sewaan (temporer) suka berganti-ganti orangnya, dan satpam sering lupa. Juga bisa masuk lewat emergency exit.

8. **Recommended Countermeasures**

a. card reader pada setiap pintu

b. identification badges akan diwajibkan

c. pemasangan kamera pemantau keamanan

# Countermeasure Evaluation Worksheet

Sheet number: 01/1

1. **Countermeasure:**

a. card reader pada setiap pintu

b. identification badges akan diwajibkan

c. pemasangan kamera pemantau keamanan

2. **Description**:

Satpam bisa mengetahui mana yang memiliki hak akses atau tidak. Satpam bisa memonitor pintu-pintu yang jauh, dengan kamera pemantau. Orang yang tidak memiliki badge dengan foto dan juga berfungsi sebagai *access card*, tidak bisa masuk ke ruangan.

Setelah dilakukan intrusion testing, ternyata unauthorized access ke ruang komputer bisa berkurang menjadi 1/10 kali-nya.

3. **Annual costs**: Rp.160 juta / 4 tahun = Rp.40 juta

4. **Threats affected by countermeasure**:

| | ALE | | |
|---|---|---|---|
| | Current | Projected | ALE Savings |
| Destruction | Rp 50 jt | Rp.5 jt | Rp.45 jt |
| Theft | Rp 200 jt | Rp. 20 jt | Rp.180 jt |
| | | **Total Savings** = | Rp.225 jt |

5. **Return on Investment**: 225 jt / 40 jt = 5,625

6. **Overlapping additional countermeasures:**

- aktifitas satpam
- kunci harus selalu terkunci pada hari Sabtu, Minggu & hari libur

# Metode perhitungan lain

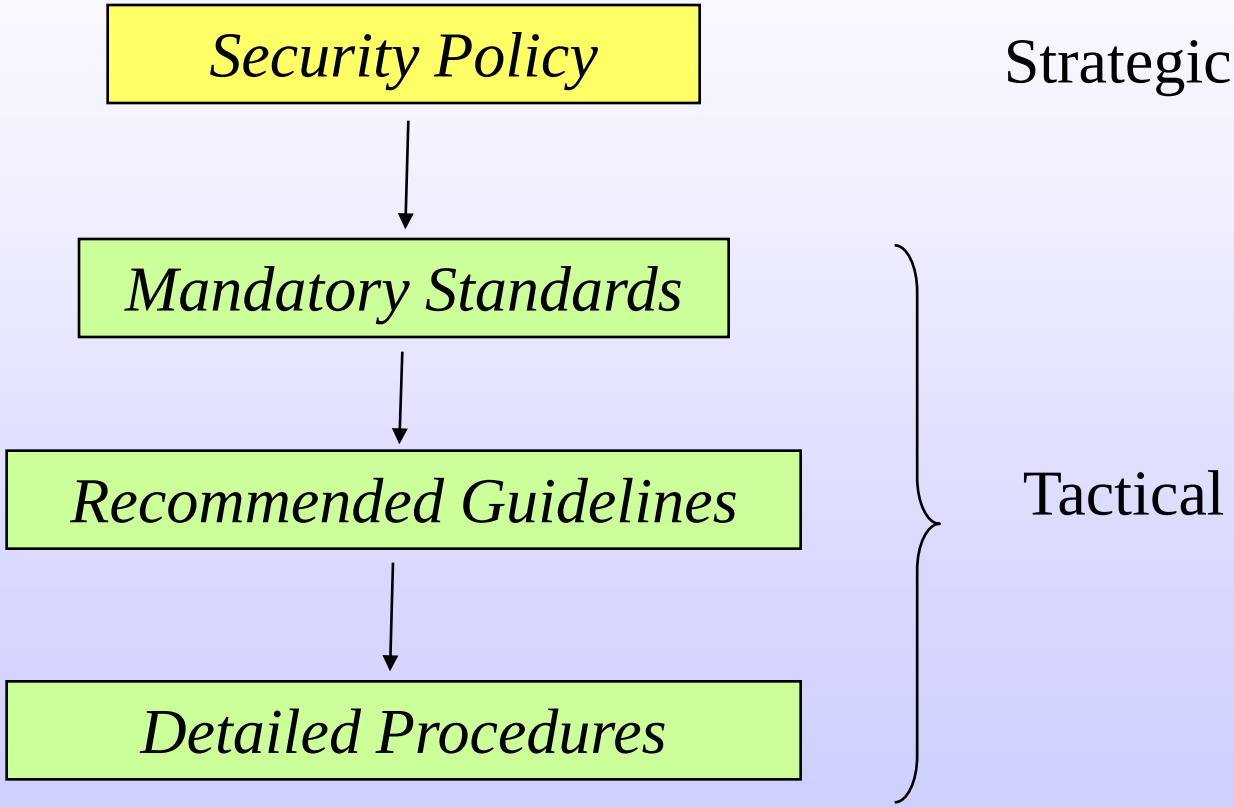
- Nilai countermeasure =

  ALE sebelum – ALE sesudah – biaya tahunan countermeasure
- Misalnya:
- ALE ancaman hacker menyerang web server adalah $12.000. Setelah memasang firewall maka ALE-nya adalah $3.000. Biaya pasang dan maintenance firewall adalah $650. Maka nilai pengaman firewall bagi perusahaan ini adalah $8.350.

# Characteristics of Safeguards / Countermeasures

- Intervensi manusia minimal
- Default pada *least previlage*
- Fungsionalitas utk mempermudah audit
- Diterima penggunaannya oleh pegawai
- Bisa diuji coba
- Tidak menyebabkan kerentantan lain
- Memiliki alarm yang tepat
- Bisa di-reset
- Ketergantungan minimal pada komponen lainnya
- Tidak mempengaruhi aset
- Pengurangan kinerja tidak banyak

# Kaitan Policy sampai Prosedur



# Case Study

- PT.ABC saat ini memiliki 10 notebook seharga $1000 sebuah. Terhadap ancaman pencuri, berdasarkan pengalaman tahun-tahun sebelumnya, terjadi 2 tahun sekali, satu notebook hilang. Badu, CISSP, mengusulkan pembelian gembok notebook yang bisa dikaitkan ke meja seharga $20 per notebook, dan gembok itu bisa dipakai selama 4 tahun. Harapannya, bisa menurunkan kemungkinan pencurian sampai 10% dibandingkan tanpa gembok.
  - Berapakah Annual Loss Expectation sebelum pemasangan gembok?
  - Berapa ALE sesudah pemasangan gembok?
  - Berapa nilai countermeasure gembok?
  - Berapa ROI?

# Klasfikasi Data Militer

- Top Secret
- Secret
- Confidential
- Sensitive
- Unclassified

# Klasifikasi Data Komersil

- Confidential
- Sensitive
- Propertiary
- Private
- Public